RAPPORT DE TEST D'INTRUSION

Prof Secure Coding — Escalate Linux

Date : 18/09/2026

Type de test : Boîte noire

Périmètre : Application web + infrastructure système locale

Classification : CONFIDENTIEL

Machine cible Linux Escalate (192.168.56.101) — Audit système local et escalade de privilèges (user vers root)

Version portfolio personnelle - contributions techniques : Ermal ZEQO

1. Introduction

1.1 Objet du document

Le présent document constitue le rapport final du test d'intrusion réalisé sur la machine Escalate (192.168.56.101). Il recense les vulnérabilités identifiées sur le périmètre audité, évalue leur criticité selon le standard CVSS 3.1, décrit les risques techniques et métiers associés et propose des recommandations de remédiation priorisées.

Ce rapport est destiné à la fois aux équipes techniques (développeurs, administrateurs système) et aux décideurs métiers. Il doit être traité comme un document CONFIDENTIEL et ne pas être diffusé en dehors des parties prenantes de la mission.

1.2 Réserves relatives à l'exhaustivité des résultats

Les résultats présentés reflètent l'état de sécurité de la cible au moment de l'audit des 17 et 18 septembre 2026, dans le cadre d'un test en boîte noire réalisé en environnement de laboratoire isolé.

- Exhaustivité non garantie : un test d'intrusion ne peut prétendre identifier la totalité des vulnérabilités d'un système.
- État instantané : des modifications post-audit peuvent introduire de nouvelles vulnérabilités.
- Périmètre restreint : seuls les éléments décrits en section 4 ont été testés.
- Absence d'impact en production : certains scénarios destructeurs n'ont pas été exploités jusqu'à leur terme.

1.3 Acteurs de l'audit

Rôle	Entité	Contact
Commanditaire	Laboratoire / environnement Escalate	-
Auditeur technique	Ermal ZEQO	-

Dates de réalisation : 17/09/2026 - 18/09/2026

2. Synthèse générale

2.1 Synthèse managériale

2.1.1 Synthèse managériale rédigée

Le test d'intrusion mené sur la machine Escalate a mis en évidence une chaîne de compromission complète, allant d'une exécution de commandes à distance non authentifiée jusqu'à l'obtention de privilèges root. Trois vulnérabilités sont classées critiques et deux hautes. VUL-05 constitue une branche complémentaire de PATH Hijacking via NFS ; la preuve de root de cette branche a été observée sur Kali et ne constitue pas, à elle seule, une preuve de root directement sur Escalate.

Constats majeurs ressortant de l'audit :

1. Une page shell.php accessible sans authentification permet l'exécution de commandes arbitraires sous user6.
2. Un binaire SUID root exécute un script externe modifiable par les utilisateurs non privilégiés.
3. VUL-01/VUL-02/VUL-03 ont été chaînées jusqu'à root sur Escalate ; VUL-05 forme une seconde branche technique.

2.1.2 Contexte et périmètre audité

La cible est une machine Linux (Escalate, 192.168.56.101) hébergeant Apache et plusieurs services de partage. Le test a été conduit depuis Kali (192.168.56.102). La chaîne principale exploite l'interface web puis des mécanismes locaux SUID. NFS et SMB ont également été identifiés ; NFS constitue le point de départ de la branche complémentaire VUL-05.

- 80/tcp — HTTP, Apache httpd 2.4.29 (Ubuntu)
- 111/tcp — rpcbind ; 2049/tcp — NFS ; 139/tcp et 445/tcp — Samba/SMB

2.1.3 Résultats de l'audit

Répartition de la gravité des vulnérabilités

Criticité	Score CVSS	Nombre
Critique	≥ 9.0	3
Haute	7.0 – 8.9	2
Moyenne	4.0 – 6.9	0
Faible	< 4.0	0

Vulnérabilités critiques et actions correctives

ID	Vulnérabilité	CVSS	Action prioritaire
VUL-01	Exécution de commandes à distance via shell.php	9.8	Retirer immédiatement shell.php du serveur
VUL-04	Chaînage complet menant à l'obtention de root	9.8	Casser la chaîne à plusieurs maillons (web, SUID, script)
VUL-05	PATH Hijacking sur un second binaire SUID via export NFS	9.8	Supprimer le SUID et restreindre l'export NFS

Bonnes pratiques observées

- Environnement de laboratoire isolé permettant une validation contrôlée.
- Nettoyage des artefacts de démonstration après le test.

Principaux axes d'amélioration

1. Supprimer les interfaces d'exécution de commandes exposées publiquement.
2. Auditer et réduire les fichiers SUID/SGID présents sur le système.
3. Renforcer les permissions des scripts privilégiés et sécuriser les exports NFS.

2.2 Synthèse des vulnérabilités

ID	Vulnérabilité	CVSS	Criticité	CWE principal
VUL-01	Exécution de commandes à distance via shell.php	9.8	Critique	CWE-78
VUL-02	Binaire SUID root /home/user3/shell	7.8	Haute	CWE-269
VUL-03	Script .script.sh modifiable par tous les utilisateurs	7.8	Haute	CWE-732
VUL-04	Chaînage complet — obtention de privilèges root	9.8	Critique	CWE-269
VUL-05	PATH Hijacking sur /home/user5/script via export NFS	9.8	Critique	CWE-426

2.3 Plan d'action

Le plan d'action est structuré en trois horizons temporels selon la criticité des vulnérabilités.

Priorité 1 — Immédiat (sous 72 heures)

ID	Action	Responsable
VUL-01	Retirer shell.php du serveur web ; auditer /var/www/html	Dev / Ops
VUL-03	Retirer les droits d'écriture « autres » sur /home/user3/.script.sh	Ops

Priorité 2 — Court terme (sous 2 semaines)

ID	Action	Responsable
VUL-02	Retirer le bit SUID de /home/user3/shell s'il n'est pas indispensable	Ops / Infra
VUL-05	Retirer le bit SUID de /home/user5/script et restreindre l'export NFS /home/user5	Ops / Infra

Priorité 3 — Moyen terme (sous 1 mois)

ID	Action	Responsable
VUL-04	Mettre en place un contrôle d'intégrité sur les scripts et binaires privilégiés	Infra
VUL-04	Réduire les privilèges du compte de service Apache et isoler les fonctions d'administration	Infra

3. Synthèse exécutive

Cinq vulnérabilités ont été identifiées : trois critiques (VUL-01, VUL-04 et VUL-05) et deux hautes (VUL-02 et VUL-03). La chaîne principale HTTP → shell.php → user6 → SUID → script modifiable → reverse shell a été validée jusqu'à uid=0(root) sur Escalate. VUL-05 correspond à une seconde branche : NFS → binaire SUID → system("ls") → PATH Hijacking ; son exécution avec uid=0(root) a été démontrée sur Kali.

Le schéma ci-dessous illustre la chaîne d'attaque, en distinguant les techniques exploitées des accès et informations obtenus à chaque étape.

Chaîne principale : HTTP → shell.php → user6 → /home/user3/shell (SUID) → .script.sh → reverse shell → root.
Branche VUL-05 : NFS /home/user5 → script (SUID) → system("ls") → PATH Hijacking → root sur Kali.

Figure 1 — Chaîne principale de compromission et branche complémentaire VUL-05.

4. Périmètre et méthodologie

Périmètre testé :

- Machine Escalate (192.168.56.101) — serveur web Apache 2.4.29 et infrastructure Linux
- Application web port 80, fichiers SUID et scripts exécutés avec privilèges root
- Services NFS (2049) et Samba/SMB (139/445) identifiés en reconnaissance

Méthodologie :

- Type de test : boîte noire — aucun accès ni identifiant fourni préalablement
- Référentiel utilisé : CVSS v3.1 ; CWE ; OWASP Top 10
- Outils utilisés : nmap, gobuster, curl, strings, file, find, netcat (nc), showmount, mount, objdump
- Restrictions : environnement de laboratoire isolé ; aucun test destructeur n'a été conduit

5. Vulnérabilités identifiées

Les fiches ci-dessous sont classées par ordre décroissant de criticité et suivent la structure du template.

VUL-01 — Exécution de commandes à distance via shell.php

Criticité	Critique
Score CVSS 3.1	9.8 / 10
Vecteur CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CWE	CWE-78 — Injection de commande OS
OWASP / Catégorie	A03:2021 — Injection

Description
Un script gobuster a révélé shell.php, accessible publiquement. Le fichier accepte un paramètre GET cmd et exécute directement son contenu comme commande système, sans authentification ni validation.
Impacts techniques
Exécution de commandes arbitraires sous le contexte user6.
Point d'entrée initial de la chaîne d'exploitation menant à VUL-04.
Impacts métiers
Accès non autorisé au système sans authentification.
Risque de compromission totale si la faille est combinée aux vulnérabilités locales.
Étapes de reproduction
1. Énumérer le contenu web avec Gobuster.
2. Identifier shell.php retournant HTTP 200.
3. Envoyer une requête avec cmd=id et constater uid=1005(user6).
4. Confirmer avec whoami et pwd.

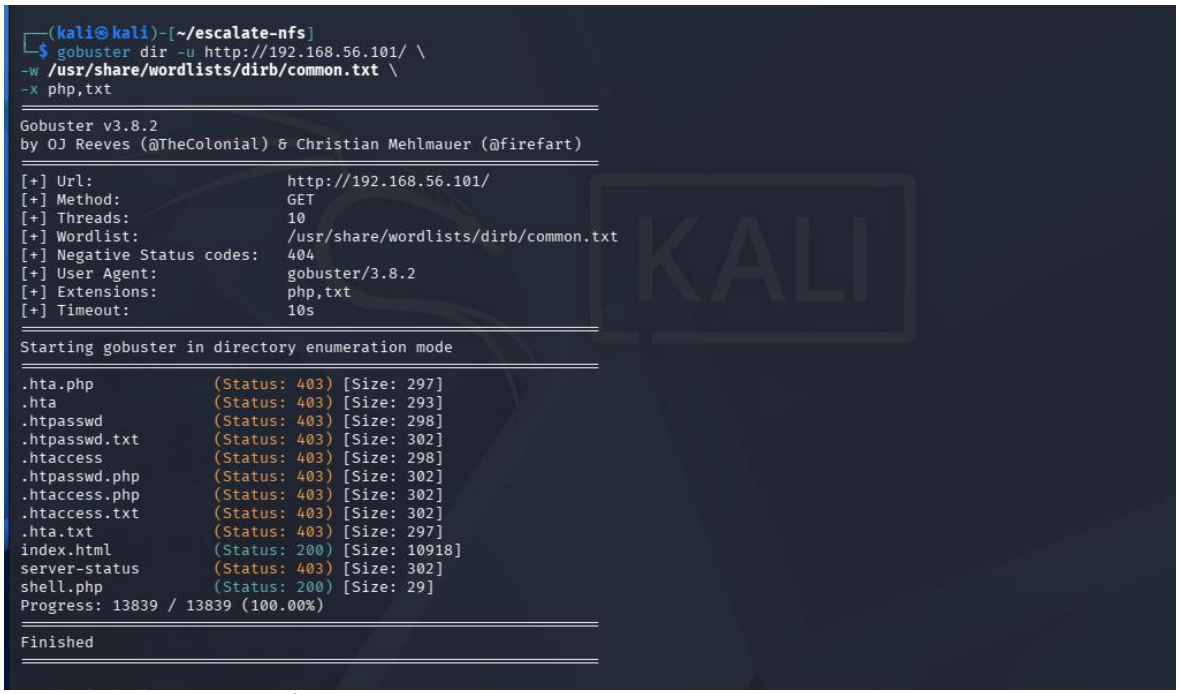


Figure 2 — Énumération du serveur web par Gobuster, révélant notamment shell.php.

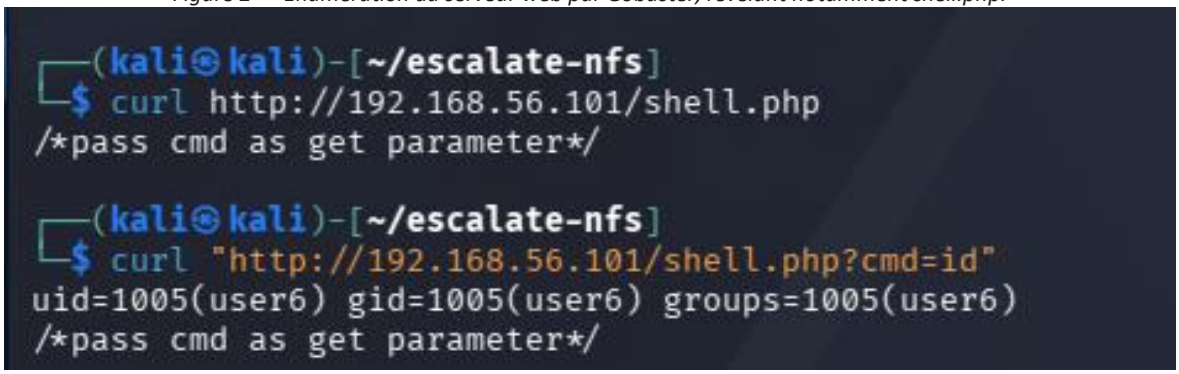


Figure 3 — Exécution de la commande id via shell.php, confirmant l'exécution distante sous user6.

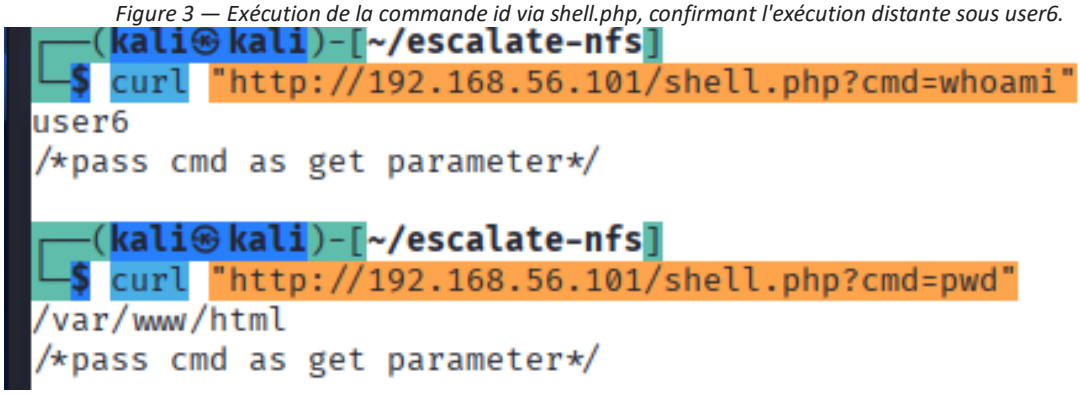


Figure 4 — Confirmation du contexte d'exécution : whoami=user6 et répertoire /var/www/html.

Remédiations

Retirer immédiatement shell.php.

Auditer /var/www/html pour détecter d'autres dépôts non autorisés.

Authentifier fortement toute fonction d'administration distante et utiliser une liste blanche.

Journaliser et surveiller les accès anormaux aux endpoints web.

Références

CWE-78 — https://cwe.mitre.org/data/definitions/78.html

OWASP Top 10 2021 — A03:2021 Injection

VUL-02 — Binaire SUID root /home/user3/shell

Criticité	Haute
Score CVSS 3.1	7.8 / 10
Vecteur CVSS	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
CWE	CWE-269 — Gestion incorrecte des privilèges
OWASP / Catégorie	A01:2021 — Contrôle d'accès défaillant

Description

L'énumération des fichiers SUID a révélé /home/user3/shell, propriétaire root:root et marqué SUID. L'analyse des chaînes montre l'utilisation de system() et une référence à ./.script.sh, recherché dans le répertoire courant.

Impacts techniques

Un utilisateur non privilégié pouvant exécuter le binaire peut potentiellement obtenir les privilèges root si le script invoqué est contrôlable.

Le binaire constitue le maillon central de l'escalade locale.

Impacts métiers

Risque d'élévation de privilèges après un premier accès au système.

Possibilité d'augmenter fortement l'impact d'une compromission web initiale.

Étapes de reproduction

1. Lister les fichiers SUID.
2. Identifier /home/user3/shell.
3. Vérifier ses permissions et son type ELF.
4. Analyser ses chaînes avec strings pour révéler system et ./.script.sh.

```
┌──(kali㉿kali)-[~/escalate-nfs]
└─$ curl --get --data-urlencode 'cmd=find / -perm -4000 -type f 2>/dev/null' "http://192.168.56.101/shell.php"
/sbin/mount.nfs
/sbin/mount.ecryptfs_private
/sbin/mount.cifs
/usr/sbin/pppd
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/traceroute6.iputils
/usr/bin/chfn
/usr/bin/arping
/usr/bin/newgrp
/usr/bin/sudo
/usr/lib/xorg/Xorg.wrap
/usr/lib/eject/dmcrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/bin/ping
/bin/su
/bin/ntfs-3g
/bin/mount
/bin/umount
/bin/fusermount
/home/user5/script
/home/user3/shell
/*pass cmd as get parameter*/
```

Figure 5 — Énumération des fichiers SUID et identification de /home/user3/shell.

```
┌──(kali㉿kali)-[~/escalate-nfs]
└─$ curl --get --data-urlencode 'cmd=ls -l /home/user3/shell' "http://192.168.56.101/shell.php"
-rwsr-xr-x 1 root root 8392 Jun  4  2019 /home/user3/shell
/*pass cmd as get parameter*/

┌──(kali㉿kali)-[~/escalate-nfs]
└─$ curl --get --data-urlencode 'cmd=file /home/user3/shell' "http://192.168.56.101/shell.php"
/home/user3/shell: setuid ELF 64-bit LSB shared object, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-li
nux-x86-64.so.2, for GNU/Linux 3.2.0, BuildID[sha1]=7bf25436e2dc7b583c76756f2753100d7b240130, not stripped
/*pass cmd as get parameter*/
```

Figure 6 — Vérification du type et des permissions du binaire /home/user3/shell.



Figure 7 — Analyse des chaînes du binaire montrant system et ./.script.sh.

Remédiations

Retirer le bit SUID s'il n'est pas strictement indispensable.

Auditer périodiquement les fichiers SUID/SGID.

Éviter system() lorsque cela n'est pas nécessaire et qualifier les chemins d'exécution.

Références

CWE-269 — https://cwe.mitre.org/data/definitions/269.html

VUL-03 — Script .script.sh modifiable par tous les utilisateurs

Criticité	Haute
Score CVSS 3.1	7.8 / 10
Vecteur CVSS	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
CWE	CWE-732 — Attribution incorrecte de permissions à une ressource critique
OWASP / Catégorie	A01:2021 — Contrôle d'accès défaillant

Description

Le fichier /home/user3/.script.sh appartient à root:root mais dispose des permissions -rwxr-xrwx. Les utilisateurs « autres » peuvent donc le modifier. Son contenu observé établit un reverse shell vers Kali:4444.

Impacts techniques

Tout utilisateur non privilégié peut modifier le script avant son exécution par le binaire SUID.

Le script devient un vecteur d'exécution de code avec les privilèges root.

Impacts métiers

Transformation d'un binaire SUID root en mécanisme d'élévation directement exploitable.

Risque de compromission totale de la machine.

Étapes de reproduction

1. Depuis user6, vérifier les permissions du script.
2. Consulter son contenu.
3. Constater la commande de reverse shell vers Kali:4444.

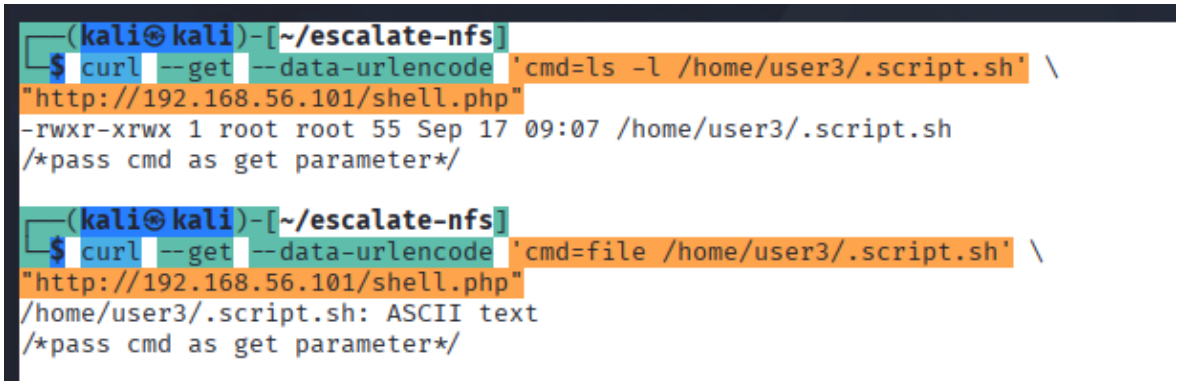


Figure 8 — Permissions de .script.sh : le fichier est inscriptible par les autres utilisateurs.

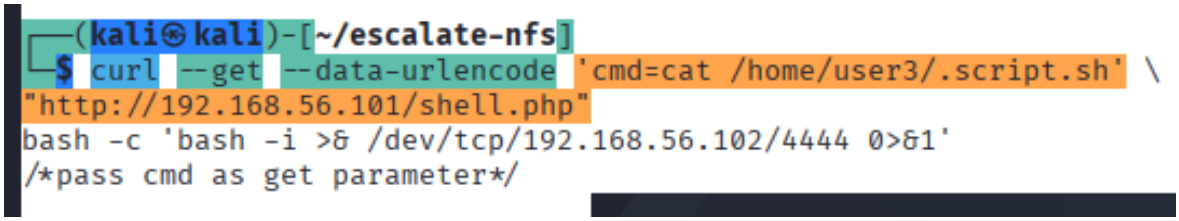


Figure 9 — Contenu de .script.sh établissant le reverse shell vers Kali:4444.

Remédiations

Retirer les droits d'écriture et d'exécution des utilisateurs « autres ».

Interdire l'écriture non privilégiée sur tout script exécuté par un binaire privilégié.

Mettre en place un contrôle d'intégrité sur les scripts sensibles.

Références

CWE-732 — https://cwe.mitre.org/data/definitions/732.html

VUL-04 — Chaînage complet permettant l'obtention de privilèges root

Criticité	Critique
Score CVSS 3.1	9.8 / 10
Vecteur CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CWE	CWE-269 — Gestion incorrecte des privilèges
OWASP / Catégorie	A01:2021 / A03:2021 combinés

Description

La combinaison de VUL-01, VUL-02 et VUL-03 a été exploitée de bout en bout. Depuis shell.php, le binaire SUID a exécuté .script.sh, établissant un reverse shell vers Kali. L'accès root a été validé par id et whoami.

Impacts techniques

Obtention d'un shell interactif avec uid=0(root) gid=0(root) sur Escalate.

Compromission potentielle de la confidentialité, de l'intégrité et de la disponibilité du système.

Impacts métiers

Compromission totale du serveur.

Accès possible aux données, configurations, comptes et services protégés.

Étapes de reproduction

1. Ouvrir une écoute Netcat sur Kali.
2. Déclencher via shell.php l'exécution de cd /home/user3 && ./shell.
3. Constater la réception du reverse shell.
4. Valider avec id et whoami l'identité root.

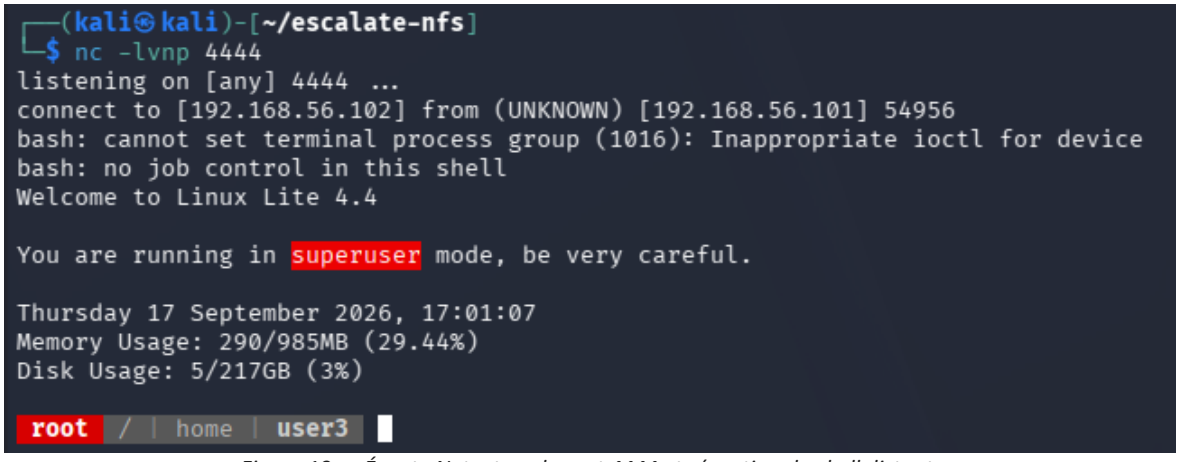


Figure 10 — Écoute Netcat sur le port 4444 et réception du shell distant.

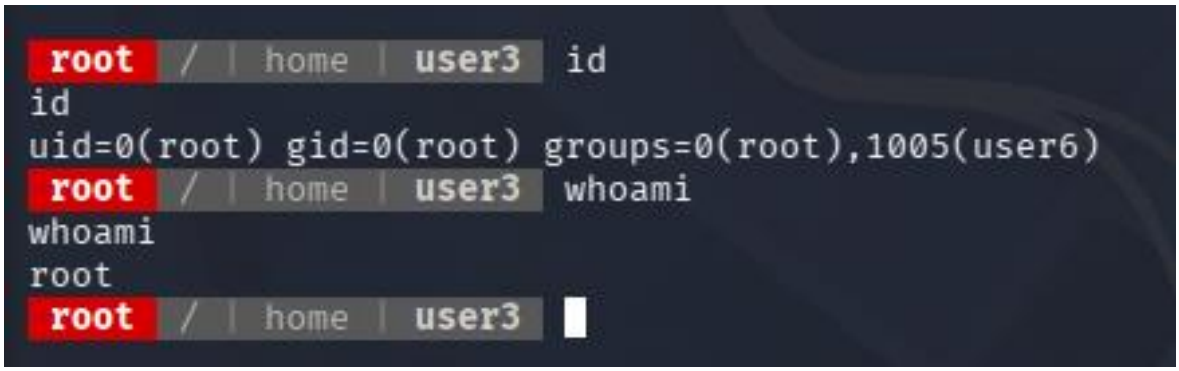


Figure 11 — Validation de l'accès root : uid=0(root) et whoami=root.

Remédiations

Supprimer shell.php.
Retirer le SUID inutile.
Protéger les scripts privilégiés.
Réduire les privilèges du compte Apache et surveiller les accès anormaux.

Références

CWE-269 — https://cwe.mitre.org/data/definitions/269.html

VUL-05 — PATH Hijacking sur un second binaire SUID via export NFS

Criticité	Critique
Score CVSS 3.1	9.8 / 10
Vecteur CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CWE	CWE-426 — Untrusted Search Path
OWASP / Catégorie	A01:2021 — Contrôle d'accès défaillant

Description

L'énumération réseau a révélé un export NFS /home/user5 accessible depuis *. Un second binaire SUID root, /home/user5/script, y est présent. Son analyse montre setuid(0) → setgid(0) → system("ls"). La commande ls est appelée sans chemin absolu et peut être détournée via la variable PATH.

Impacts techniques

Un faux ls placé en tête du PATH est exécuté par le binaire SUID avec uid=0(root).
Le mécanisme de PATH Hijacking est techniquement confirmé sur la machine cliente Kali.

Impacts métiers

Un binaire privilégié peut exécuter un programme contrôlé par un utilisateur non privilégié.
Si exploitable dans le contexte de la cible, le mécanisme peut conduire à une élévation de privilèges et à une compromission des ressources protégées.

Étapes de reproduction

1. Monter 192.168.56.101:/home/user5 depuis Kali.
2. Identifier /home/user5/script et vérifier son caractère SUID root.
3. Analyser le binaire et constater setuid(0), setgid(0) et system("ls").
4. Créer /tmp/path-test/ls contenant id et le rendre exécutable.
5. Placer /tmp/path-test en tête du PATH et exécuter le binaire.
6. Constater uid=0(root) gid=0(root).

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-18 03:27 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-d
ns or specify valid servers with --dns-servers
Nmap scan report for 192.168.56.101
Host is up (0.00096s latency).
Not shown: 995 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
80/tcp   open  http        Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
111/tcp  open  rpcbind     2-4 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2,3,4        111/tcp   rpcbind
|   100000  2,3,4        111/udp   rpcbind
|   100000  3,4          111/tcp6  rpcbind
|   100000  3,4          111/udp6  rpcbind
|   100003  3           2049/udp   nfs
|   100003  3           2049/udp6  nfs
|   100003  3,4         2049/tcp   nfs
|   100003  3,4         2049/tcp6  nfs
|   100005  1,2,3      38253/tcp   mountd
|   100005  1,2,3      42919/udp6  mountd
|   100005  1,2,3      58511/tcp6  mountd
|   100005  1,2,3      59138/udp   mountd
|   100021  1,3,4      44591/tcp6  nlockmgr
|   100021  1,3,4      45113/tcp   nlockmgr
|   100021  1,3,4      51600/udp   nlockmgr
|   100021  1,3,4      56101/udp6  nlockmgr
|   100227  3           2049/tcp   nfs_acl
|   100227  3           2049/tcp6  nfs_acl
|   100227  3           2049/udp   nfs_acl
|_  100227  3           2049/udp6  nfs_acl
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 4.7.6-Ubuntu (workgroup: WORKGROUP)
2049/tcp open  nfs         3-4 (RPC #100003)
MAC Address: 08:00:27:7A:D5:86 (Oracle VirtualBox virtual NIC)
Service Info: Host: LINUX
```

Figure 12 — Reconnaissance Nmap : HTTP, RPCbind, NFS et SMB exposés sur la cible.

```
┌──(kali㉿kali)-[~]
└─$ sudo mount -t nfs 192.168.56.101:/home/user5 ~/nfs

┌──(kali㉿kali)-[~]
└─$ mount | grep '/home/user5'
192.168.56.101:/home/user5 on /home/kali/escalate-nfs type nfs4 (rw,relatime,vers=4.2,rsize=131072,wsize=131072,na
mlen=255,hard,fatal_neterrors=none,proto=tcp,timeo=600,retrans=2,sec=sys,clientaddr=192.168.56.102,local_lock=none
,addr=192.168.56.101)
192.168.56.101:/home/user5 on /home/kali/nfs type nfs4 (rw,relatime,vers=4.2,rsize=131072,wsize=131072,namlen=255,
hard,fatal_neterrors=none,proto=tcp,timeo=600,retrans=2,sec=sys,clientaddr=192.168.56.102,local_lock=none,addr=192
.168.56.101)

┌──(kali㉿kali)-[~]
└─$ ls -la ~/nfs
total 160
drwxr-xr-x 22 1004 1004 4096 Jun  4  2019 .
drwx------ 23 kali kali 4096 Sep 17 09:34 ..
-rw-r--r--  1 1004 1004  124 Jun  4  2019 .asoundrc
-rw-r--r--  1 1004 1004  220 Jun  4  2019 .bash_history
-rw-r--r--  1 1004 1004  220 Jun  4  2019 .bash_logout
-rw-r--r--  1 1004 1004  949 Jun  4  2019 .bashrc
drwxr-xr-x 15 1004 1004 4096 Jun  4  2019 .cache
drwxr-xr-x 20 1004 1004 4096 Jun  4  2019 .config
drwxr-xr-x  3 1004 1004 4096 Jun  4  2019 .dbus
drwxr-xr-x  2 1004 1004 4096 Jun  4  2019 Desktop
-rw-r--r--  1 1004 1004   23 Jun  4  2019 .dmrc
drwxr-xr-x  2 1004 1004 4096 Jun  4  2019 Documents
drwxr-xr-x  2 1004 1004 4096 Jun  4  2019 Downloads
-rw-r--r--  1 1004 1004 9354 Jun  4  2019 .face
drwxr-xr-x  2 1004 1004 4096 Jun  4  2019 .gconf
drwxr-xr-x 24 1004 1004 4096 Jun  4  2019 .gimp-2.8
-rw-r--r--  1 1004 1004    0 Jun  4  2019 .gksu.lock
drwxr-xr-x  3 1004 1004 4096 Jun  4  2019 .gnome
drwxr-xr-x  3 1004 1004 4096 Jun  4  2019 .gnome2
drwxr-xr-x  3 1004 1004 4096 Jun  4  2019 .gnupg
-rw-r--r--  1 1004 1004   20 Jun  4  2019 .gtk-bookmarks
-rw-r--r--  1 1004 1004  105 Jun  4  2019 .gtkrc-2.0
-rw-------  1 1004 1004 4710 Jun  4  2019 .ICEauthority
drwxr-xr-x  3 1004 1004 4096 Jun  4  2019 .local
-rwxrwxr-x  1 1004 1004   26 Jun  4  2019 ls
drwxr-xr-x  5 1004 1004 4096 Jun  4  2019 .mozilla
drwxr-xr-x  2 1004 1004 4096 Jun  4  2019 Music
drwxr-xr-x  2 1004 1004 4096 Jun  4  2019 Pictures
-rw-r--r--  1 1004 1004  873 Jun  4  2019 .profile
drwxr-xr-x  2 1004 1004 4096 Jun  4  2019 Public
-rwsr-xr-x  1 root root 8392 Jun  4  2019 script
-rw-r--r--  1 1004 1004    0 Jun  4  2019 .sudo_as_admin_successful
drwxr-xr-x  2 1004 1004 4096 Jun  4  2019 Templates
drwxr-xr-x  3 1004 1004 4096 Jun  4  2019 .thumbnails
drwxr-xr-x  4 1004 1004 4096 Jun  4  2019 .thunderbird
drwxr-xr-x  2 1004 1004 4096 Jun  4  2019 Videos
-rw-r--r--  1 1004 1004   50 Jun  4  2019 .Xauthority
```

Figure 13 — Montage du partage NFS /home/user5 et identification du binaire SUID script.

```
┌──(kali㉿kali)-[~]
└─$ objdump -d ~/nfs/script | grep -A20 '<main>'
 5ed:   48 8d 3d e6 00 00 00    lea    0xe6(%rip),%rdi        # 6da <main>
 5f4:   ff 15 e6 09 20 00       call   *0x2009e6(%rip)        # 200fe0 <__libc_start_main@GLIBC_2.2.5>
 5fa:   f4                      hlt
 5fb:   0f 1f 44 00 00          nopl   0x0(%rax,%rax,1)

0000000000000600 <deregister_tm_clones>:
 600:   48 8d 3d 09 0a 20 00    lea    0x200a09(%rip),%rdi        # 201010 <__TMC_END__>
 607:   55                      push   %rbp
 608:   48 8d 05 01 0a 20 00    lea    0x200a01(%rip),%rax        # 201010 <__TMC_END__>
 60f:   48 39 f8                cmp    %rdi,%rax
 612:   48 89 e5                mov    %rsp,%rbp
 615:   74 19                   je     630 <deregister_tm_clones+0x30>
 617:   48 8b 05 ba 09 20 00    mov    0x2009ba(%rip),%rax        # 200fd8 <_ITM_deregisterTMCloneTable>
 61e:   48 85 c0                test   %rax,%rax
 621:   74 0d                   je     630 <deregister_tm_clones+0x30>
 623:   5d                      pop    %rbp
 624:   ff e0                   jmp    *%rax
 626:   66 2e 0f 1f 84 00 00    cs nopw 0x0(%rax,%rax,1)
 62d:   00 00 00
 630:   5d                      pop    %rbp
 631:   c3                      ret
--
00000000000006da <main>:
 6da:   55                      push   %rbp
 6db:   48 89 e5                mov    %rsp,%rbp
 6de:   bf 00 00 00 00          mov    $0x0,%edi
 6e3:   b8 00 00 00 00          mov    $0x0,%eax
 6e8:   e8 c3 fe ff ff          call   5b0 <setuid@plt>
 6ed:   bf 00 00 00 00          mov    $0x0,%edi
 6f2:   b8 00 00 00 00          mov    $0x0,%eax
 6f7:   e8 a4 fe ff ff          call   5a0 <setgid@plt>
 6fc:   48 8d 3d a1 00 00 00    lea    0xa1(%rip),%rdi        # 7a4 <_IO_stdin_used+0x4>
 703:   b8 00 00 00 00          mov    $0x0,%eax
 708:   e8 83 fe ff ff          call   590 <system@plt>
 70d:   b8 00 00 00 00          mov    $0x0,%eax
 712:   5d                      pop    %rbp
 713:   c3                      ret
 714:   66 2e 0f 1f 84 00 00    cs nopw 0x0(%rax,%rax,1)
 71b:   00 00 00
 71e:   66 90                   xchg   %ax,%ax

0000000000000720 <__libc_csu_init>:
 720:   41 57                   push   %r15
```

Figure 14 — Désassemblage du binaire : appels à setuid(0), setgid(0) et system().



Figure 15 — Preuve du PATH Hijacking : le faux ls est exécuté et obtient uid=0(root).

Limite constatée

Le test a confirmé le mécanisme de PATH Hijacking et l'exécution du faux ls avec uid=0(root), mais la démonstration a été réalisée sur Kali après montage du partage NFS. Le hostname observé est « kali » : cette preuve ne démontre donc pas une élévation de privilèges directement sur Escalate. Elle confirme en revanche la vulnérabilité du binaire SUID provenant d'Escalate et son comportement dangereux lorsqu'il utilise system("ls") sans chemin absolu.

Remédiations

Qualifier tout appel système par un chemin absolu, par exemple /usr/bin/ls.

Éviter system() lorsque cela n'est pas nécessaire et utiliser un mécanisme d'exécution contrôlé.

Retirer le bit SUID de /home/user5/script s'il n'est pas indispensable.

Restreindre l'export NFS /home/user5 à des clients identifiés et éviter les exports en *.

Références

CWE-426 — Untrusted Search Path.

Documentation de l'audit — analyse du binaire /home/user5/script et vérification du PATH Hijacking.

6. Annexes

6.1 Preuves de nettoyage

Les artefacts déposés par l'équipe d'audit durant le test sont les suivants :• /tmp/path-test/ls, faux exécutable créé sur Kali pour VUL-05 — supprimé à l'issue du test.• Session reverse shell obtenue via .script.sh — session fermée en fin de démonstration, sans persistance additionnelle. Les fichiers shell.php et les binaires SUID analysés (/home/user3/shell, /home/user3/.script.sh, /home/user5/script) étaient préexistants sur la cible.

6.2 Scripts et outils développés

faux-ls (PATH Hijacking)

Script shell minimal contenant la commande id, utilisé sur Kali uniquement pour démontrer le détournement de la résolution de ls par la variable PATH dans VUL-05.